

# SecureIT Entra ID Authentication Plan

Prepared for SecureIT on 2026-06-22.

Current login flow status: development-only routing based on local seed data. This plan replaces it with proper Microsoft Entra ID sign-in for customers and ICT365 administrators. Current implementation status: the Entra login, callback, and logout hooks now exist in the codebase, but phase 4 validation is still needed before the flow is treated as production-ready.

## 1. Goal

Use Microsoft Entra ID as the only sign-in method for the SecureIT web app so customer tenants land in their own portal and ICT365 staff land in the admin area.

## 2. Recommended Identity Model

Use one multi-tenant Entra app registration for SecureIT.

Use the authorization code flow with PKCE.

Use a server-side session after the callback. Do not trust query-string routing or client-side identity flags. The current code already follows this model; the remaining work is validating the flow against real tenants and production Entra configuration.

Use claims to decide access:

- 'tid' maps the sign-in to a SecureIT tenant record.
- an admin app role or admin group membership grants access to ICT365-only pages.
- customer users are routed to the tenant that matches their Entra tenant ID.

## 3. Entra Portal Setup

Create a new app registration for SecureIT.

Recommended account type: accounts in any organizational directory.

Add web redirect URIs for the SecureIT callback and logout return path.

For local testing, use 'http://localhost:8088/auth/callback' rather than '127.0.0.1'.

Register the logout return URL as a normal redirect URI, for example 'https://secureit.ict365.ky/login.php' and 'http://localhost:8088/login.php'.

Set the front-channel logout URL to the logout hook, for example 'https://secureit.ict365.ky/auth/logout'.

If you need local single sign-out testing, use the matching local logout hook instead of '127.0.0.1'.

Enable ID token and authorization code sign-in.

Create an admin app role such as 'SecureIT.Admin'.

Assign that role only to ICT365 staff or an ICT365 admin group.

If ICT365 sign-ins all use the '@ict365.ky' domain, SecureIT can also treat that domain as admin by default during phase 4 validation. That domain-based admin rule is currently implemented for the first validation pass.

If you want stronger customer governance, restrict approved customer tenants by tenant ID in SecureIT and require admin consent during onboarding.

## 4. App Configuration

Add separate Entra auth settings to SecureIT config and environment variables. The current app already reads these settings from environment variables.

Suggested variables:

- 'SECUREIT\_ENTRA\_TENANT\_ID'
- 'SECUREIT\_ENTRA\_CLIENT\_ID'
- 'SECUREIT\_ENTRA\_CLIENT\_SECRET'
- 'SECUREIT\_ENTRA\_REDIRECT\_URI'
- 'SECUREIT\_ENTRA\_POST\_LOGOUT\_REDIRECT\_URI'
- 'SECUREIT\_ENTRA\_ALLOWED\_TENANT\_IDS'
- 'SECUREIT\_ENTRA\_ADMIN\_GROUP\_ID' or 'SECUREIT\_ENTRA\_ADMIN\_APP\_ROLE'

Keep these separate from the existing Key Vault and reporting settings.

## 5. App Changes

Replace the current login router in 'app/login.php' with a redirect to Microsoft sign-in.

Add a callback endpoint that validates state, nonce, issuer, audience, and token signature.

Store only the minimum identity facts in the session: email, name, Entra tenant ID, object ID, role, and resolved SecureIT tenant key.

Add access guards so:

- admin pages require the admin role
- customer pages require a matched tenant record
- unauthorised users are sent back to login with a clear error

Update logout so it clears the SecureIT session and, optionally, returns the user to the Entra logout endpoint. These code paths are already present; the remaining task is to validate their behaviour end to end.

## **6. Tenant Routing Rules**

Use the signed-in user's Entra tenant ID to resolve the customer portal.

If one Entra tenant maps to one SecureIT tenant, route directly to that tenant page.

If one user can access multiple customer tenants, add a post-login tenant picker. Do not let the user choose a tenant before authentication.

Keep ICT365 admin access separate from customer access so the admin dashboard does not depend on customer tenant mapping.

## **7. Rollout Plan**

Phase 1: create the Entra app registration and confirm callback URLs.

Phase 2: build the callback/session layer and keep the old login only as a localhost-only fallback for 'fab@local' and 'con@local'.

Phase 3: wire admin and customer access checks into the existing page guards.

Phase 4: onboard one ICT365 admin account and one customer tenant for validation.

Phase 5: remove the seed-based login shortcut from any non-localhost runtime paths.

Phase 6: document the onboarding steps for new customer tenants.

## **8. Security Checklist**

Validate JWT signatures against Entra JWKS.

Check the issuer, audience, nonce, and token expiry on every login.

Use secure, HttpOnly, SameSite cookies.

Do not store user passwords in SecureIT.

Do not route access based on email text alone.

Keep audit logs for sign-in success, failure, and role checks.

## **9. Practical Next Step**

Start with a single SecureIT Entra app registration, admin role assignment, and a callback proof of concept. Once that works, connect tenant mapping and then replace the development login flow.